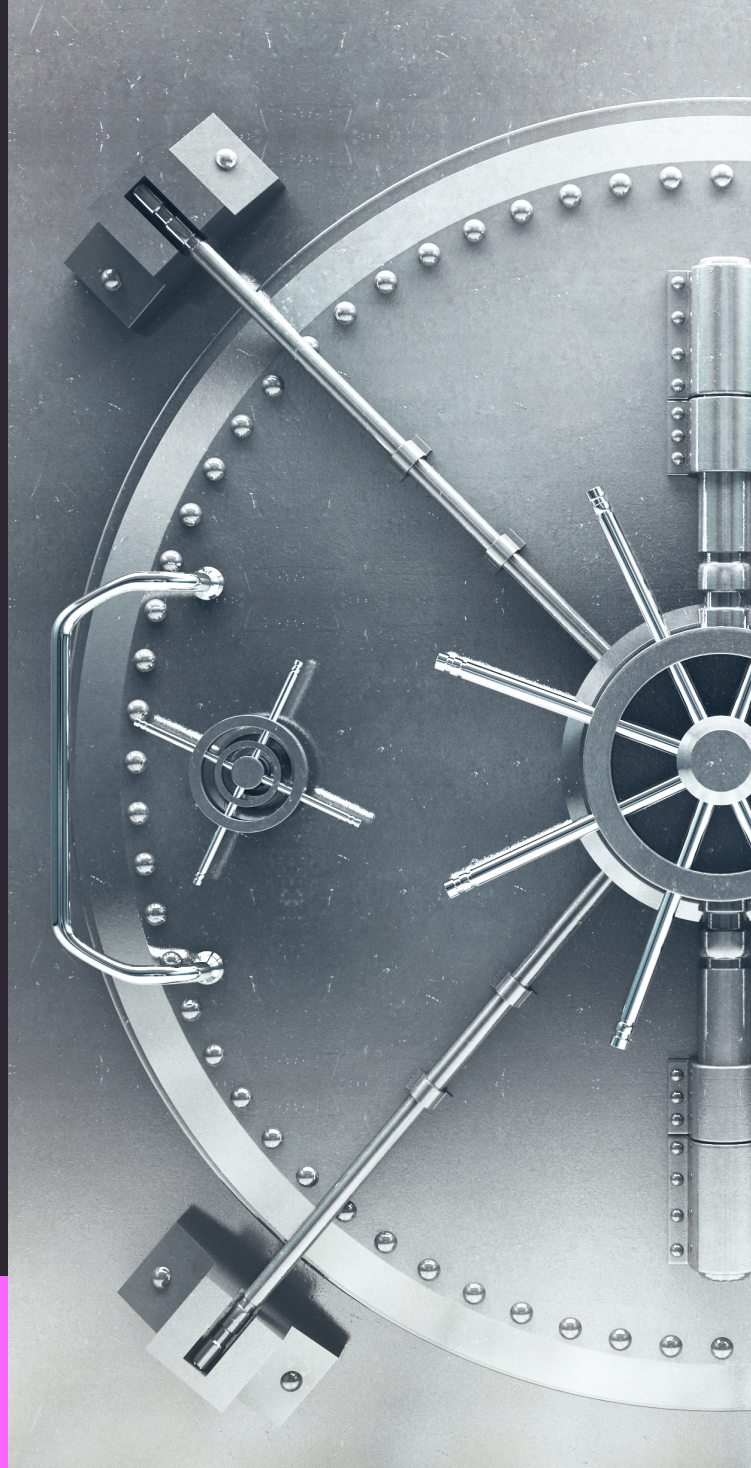


TAURUS

June 2023

Technology report



TAURUS

Banking-grade digital asset custody

Our multi-layer custody framework, beyond signing machines

Table of content

Foreword to the updated version	3
Preamble	4
I. Design goals of a custody solution	5
Access management controls: Reflect any bank's target operating model	7
Compliance controls: Transpose compliance requirements	7
Risk management controls: Cover operational risk	7
Transaction and signature mechanisms: Securely build and sign transactions	8
Blockchain communication: Include a reliable gateway to blockchains	8
Financial management mechanisms: Integrate with banks' business processes	8
Audit (tech and compliance): Ensure accountability and auditability of the solution	8
Business continuity & disaster recovery: BCP and DRP planning can ensure	7
II. Security goals of a custody solution	8
Prevent direct access to the seeds or keys	9
Leverage reliable security technologies: HSMs and MPC	9
Prevent unauthorized access to signing capabilities	9
Prevent unauthorized transactions	10
Generate keys securely	10
Ensure reliable back-ups	10
Ensure logs and databases security	10
Ensure solution's auditability	11
Ensure supply chain and build integrity	11
Ensure segregation of duties	11
III. HSM and MPC: different beasts, different roles	12
The role of an HSM	12
The role of MPC	12
MPC and security	13
Taurus and MPC	14
IV. Custody and servicing of securities	15
Further reading	16

Foreword to the updated version

In the fast-paced world of technology, especially in the ever-evolving spheres of cryptocurrency and blockchain, three years is tantamount to a lifetime. Our dedicated readers may recall a report we shared back in October 2020 regarding banking-grade custody solutions intended for business and technology leaders looking to implement digital asset infrastructure. As we approach the three-year mark, both the technological and regulatory terrains have seen substantial shifts. In the meantime, Taurus has not only broadened its geographical reach and offerings but also matured. This growth prompted us to revisit and update the original document.

Although our core beliefs remain unchanged, we've amplified the initial document by including more intricate details on the design and security of custody solutions, refining the shared responsibility model, elaborating on multi-party computation. Finally, taking into account the evolution of regulation with respect to tokenized securities, we supplemented our document with a section on asset servicing functionalities and additional references.

Over the past three years, despite fluctuating trends and occasional "crypto winters", the consistency of our model and strategic choices coupled with the increasing diversity of clients embracing our solution, attests to the viability of our approach. Our belief is anchored in establishing enduring, strategic partnerships with our clients, underpinned by robust engineering and an unwavering commitment to security. While we stay abreast of trends and new technologies—evidenced by our investment in zero-knowledge technologies and post-quantum cryptography—we steadfastly refrain from short-term profits or opportunistic ventures that could compromise our clients' security. Instead, we maintain a balance of caution and conservatism in our design choices.

We trust that you will find this updated report insightful.

Dr. Jean-Philippe Aumasson
CSO, Co-founder at Taurus SA
June 2023

Preamble

At Taurus, we have accompanied numerous corporations and financial institutions with global operations in integrating and deploying digital assets in their business, by providing them with our digital asset infrastructure and technology as well as supporting its integration in banking-grade production environments.

We use the same products as our clients for our own business, be it Taurus-PROTECT (hot, warm, and cold custody), Taurus-EXPLORER (blockchain nodes), or Taurus-CAPITAL (issuance and lifecycle management of tokenized assets and securities). We thus strive to keep these products superior to alternative solutions with respect to all applicable metrics, be it security, ease-of-use, banking-readiness, and total cost of ownership.

Our engineers have helped leading cryptocurrency and digital asset exchanges securing their cold wallets, among other projects related to digital assets custody and several management team members have held executive roles in leading security or financial institutions. We have notably leveraged this experience when leading the creation, and the recent update, of the CMTA Digital Assets Custody Standard,¹ and when reviewing the security of custody solutions, starting with our own products.

Based on this dual technology and financial services perspective, this article shares our views on what constitutes a modern digital asset custody solution, with a focus on security assurance as well as its technical and integration aspects. It is written with banking executives (business or technical), auditors, and regulators in mind as target readers. In the remainder of the article, Section II highlights the main components of banking-grade digital asset custody platforms; Section III covers the objectives of such platforms; Section IV concludes with a perspective on multi-party computation technologies.

A one-sentence summary would be the following: production-ready, banking-grade custody platforms should go way beyond simplistic signing machines that new entrants or mono players may think of and should gear for any type of assets: cryptocurrencies, tokenized securities, digital currencies.

Have a good read.

Dr. Jean-Philippe Aumasson
CSO, Co-founder at Taurus SA
October 2020

¹ See <https://cmta.ch> and <https://cmta.ch/standards/digital-assets-custody-standard>

I. Design goals of a custody solution

Definition

In the present context, a digital asset custody solution can be roughly defined as a system that

- Safeguards assets whose ownership and control is realized by means of cryptographic techniques and depends on the access to a cryptographic secret, typically a private signing key;
- Provides value added functionalities such as interacting securely with smart-contract functions and servicing tokenized securities;
- Does so in the context of (regulated) financial institutions, where the custodian bears legal responsibility, be it safeguarding client's assets or their own.

The term "banking-grade solutions" underscores that these offerings must surpass the rudimentary features provided by consumer-grade wallets. More importantly, the security assurance of these solutions should be proportional to the risk and value involved. For instance, numerous banks that were early adopters of cryptocurrency initially relied on top-tier hardware wallet devices, akin to what many consumers use. Yet, they had to implement a host of specialized procedures and develop bespoke software components to meet the baseline security and compliance mandates for their institutions. As the utilization of these systems broadened in terms of volume, diversity of tokens, and transaction types, it became apparent that the existing model was simply inadequate.

Beyond signing machines

A banking-grade digital asset custody solution needs much more than merely serving as a "signing machine" or an elevated consumer wallet. It must comprehensively address the safekeeping and management needs of digital assets for regulated financial institutions. More than just safeguarding private keys, a custody solution must meet operational and compliance requirements such as user authentication, role-based access, data integrity, service availability, audit trails, scalability, and business continuity.

These banking-grade solutions must empower user institutions to uphold fundamental security principles like authentication, compliance, monitoring, and the segregation of duties.

The formulation and execution of associated features should not compromise the institution's security stance, but rather, align with its policies and approved security mechanisms. It's imperative that these solutions cater to the unique needs of financial institutions, focusing on key areas including but not limited to:

- Authentication: Password policies, multi-factor authentication (MFA) type, single sign-on (SSO) protocol.
- Compliance: Address scoring provider, address and smart contract whitelisting capabilities, asset servicing capabilities.
- Monitoring: Logs structure and type, support for various security information and event management (SIEM) solutions.
- Segregation of duties: Type and number of roles, quorum-based approval, deployment model.

Considering the diversity of functions and security controls, it is beneficial to deconstruct a custody solution into various components, thereby clarifying its purpose and the parties responsible. This is the objective of our proposed shared responsibility model.

Shared responsibility model

The concept of shared responsibility model was popularized among security practitioners by that of AWS.² This was created from the premise that the onus of security and compliance in cloud services is mutually borne by the provider and the client. For instance, while the cloud provider's duty is to provide a reliable admin authentication system with robust password enforcement and multi-factor authentication (MFA), it falls upon the user to ensure the password and MFA token aren't shared with colleagues, friends, or family members.

When it comes to banking-grade custody solutions, we need an application specific model, rather than AWS' general, PaaS/IaaS-oriented model. Our proposed model dissects a custody solution into several constituent blocks, with some being standalone and others spanning multiple areas.

² <https://aws.amazon.com/compliance/shared-responsibility-model/>

Our model, represented in Figure 1, segregates these blocks into three categories:

- **Fully part** of the custody solution, whose implementation and reliability is mainly the responsibility of the provider (and its subcontractors),
- **External components** that the provider cannot control, be they from the client or other parties,
- Partially under the mutual responsibility of the provider and of the client, depending on the deployment model (from fully on-premise to fully managed).

The level of detail is limited for both space and intellectual property reasons.

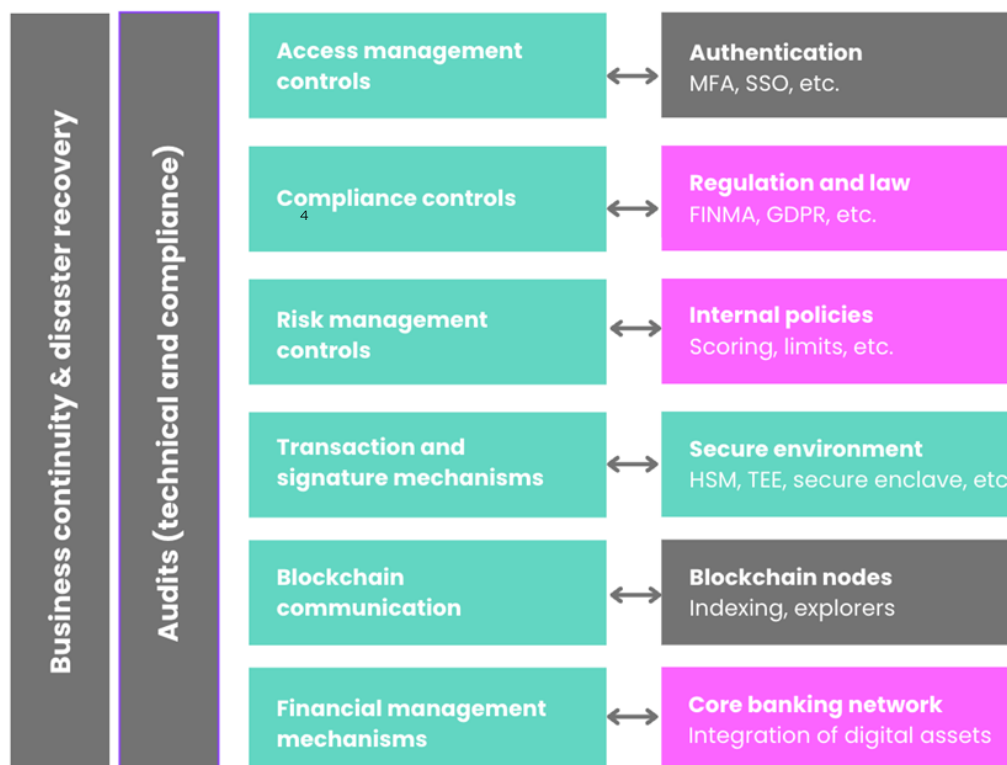


Figure 1: Shared responsibility model

Key takeaway

As shown by the above model, production-level custody solutions for banks go way beyond secure signing and key storage (what we call “signing machines”). Technology and service providers shall not limit themselves to solving the signature layer at the risk of having to build unreliable unintegrated patches of components from multiple suppliers, or exploding the budget allocated.

Let's give examples of what these blocks are about:

1. Access management controls: Reflect any bank's target operating model

- Role-based access control with audit trail
- API-based and GUI access
- Connectivity with third-party counterparties and/or liquidity providers
- Support of strong authentication with multiple factors
- Support of SSO protocols

2. Compliance controls: Transpose compliance requirements

- Know-your-customer (KYC) and anti-money laundering (AML) checks
- Know-your-transaction (KYT) risk scoring, risk alerts, automated fraud detection
- Travel rule compliance
- Wallet, address, fund quarantining
- Cryptographic proof-of-reserve
- Extensive audit trail and activity logs

3. Risk management controls: Cover operational risk

- Address whitelisting and blacklisting
- Transaction rules (amount, time of day, etc.)
- Rate-limiting functions (amounts, transaction), configurable at multiple levels
- Emergency kill switch
- Downgrade attack and replay prevention

4. Transaction and signature mechanisms: Securely build and sign transactions

- Secure seed and key storage
- Blockchain transaction creation
- Transaction signature incl. hierarchical key derivation
- Support different elliptic curves and signature schemes
- Offer support for threshold signing (multi-party computation of signatures)

5. Blockchain communication: Include a reliable gateway to blockchains

- Often overlooked by providers, who may rely on public nodes with little or no SLA
- Reliable broadcasting of transactions
- Real-time monitoring of wallet addresses
- Privacy of blockchain—IP/originator information
- Mitigation of front-running attacks

6. Financial management mechanisms: Integrate with banks' business processes

- Issuance, booking, transfer, and processing of corporate actions of any type of digital asset (cryptocurrency, tokenized asset, stablecoin)
- Treasury management incl. nostro and vostro management
- Reconciliation and reporting
- Core banking interfacing and reconciliation (incl. SWIFT financial messaging)
- Order management system interfacing

Furthermore, the following transversal blocks cover all of the above:

7. Audit (tech and compliance): Ensure accountability and auditability of the solution

- Business and audit trail generation and integrity protection
- Connection to log management systems and SIEMs
- Technical security assessments (pentest, code review)
- Compliance and certification audits

8. Business continuity & disaster recovery: BCP and DRP planning can ensure

- Redundant active-active instances and back-ups
- High-availability network services
- Avoidance of vendor lock-in
- Contingency measures testing (failover, restoration, emergency situations, etc.)

II. Security goals of a custody solution

Security & reliability is the most important property of banking-grade custody solutions, be it

- Against external attackers, insiders, or accidental failures.
- In terms of asset control (thus private keys protection), but also of data integrity, keys restorability, audit trail, and other aspects sometimes overlooked.
- In terms of pure technical security (think, software vulnerabilities and exploits) or support and choice of security protocols (such multi-party approval, single sign-on, disaster recovery) .
- In terms of trust assumptions, from trusted hardware to cryptographic protocols' security level.

Ensuring high security assurance necessitates an array of security controls, both procedural and technical, along with redundancy, a defense-in-depth strategy, and rigorous, varied testing. To attain these objectives, our approach to security architecture draws from the bedrock principles of secure systems established in the 1980s. As illustrated in Figure 2 by the NSA, these principles—comprising auditability, reliability, manageability, adaptability, and dependability—continue to hold significant relevance today.

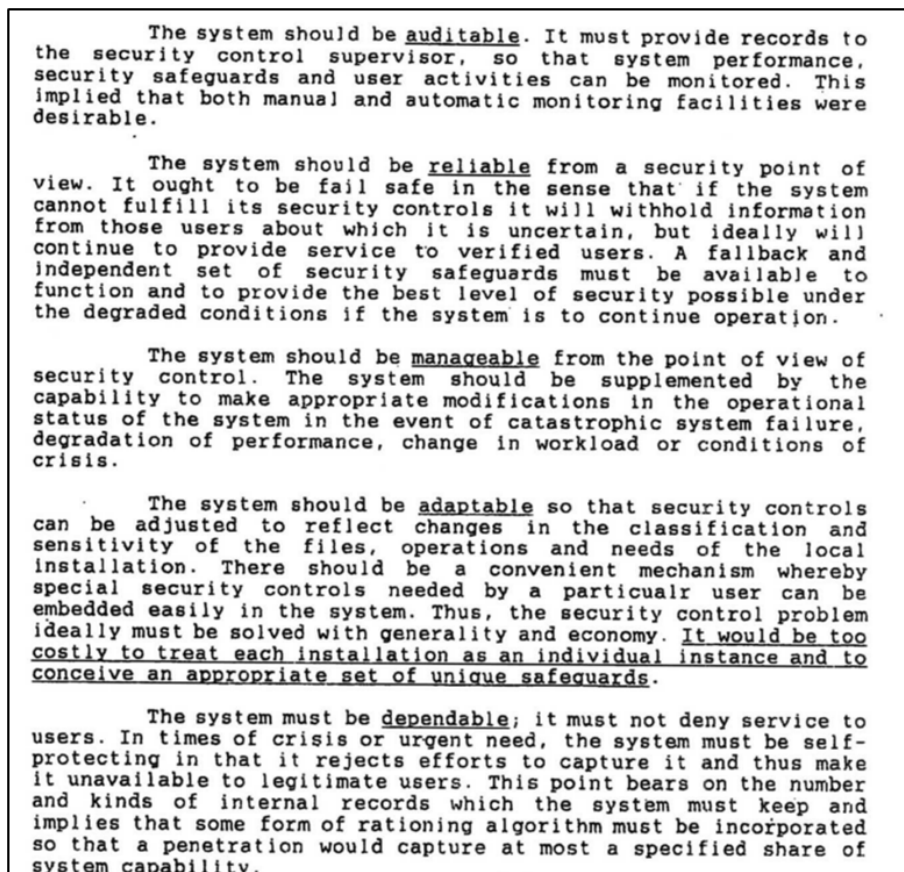


Figure 2: Some of the "general characteristics (...) desirable in a secure system", as described in NSA's 1998 History of Computer Security.³

³ Available at <https://cryptome.org/2020/10/nsa-history-computer-security-1998.pdf>.

In the following, let's discuss certain of the specific security goals addressed in our design of digital asset custody solution.

Prevent direct access to the seeds or keys

A digital asset account is characterized by a key pair, whose

- Private key is used to sign transactions issued from the account (thus, allowing transfer of assets), and thus must only be used by authorized parties.
- Public key is used to verify signatures (that is, endorsements) of transactions, and to derive the address of the account.

(Note that accounts can also be configured to require multi-signatures, that is, endorsement of signatures by multiple parties/keys—which is distinct from multi-party computation.)

"Seed" refers to the master secret from which private keys are derived, typically following de facto blockchain standard constructions BIP-32, BIP-44, and SLIP10. In many cases it is more convenient and scalable to store a seed, in order to derive arbitrarily many key pairs (and thus blockchain accounts) from it. Furthermore, it is also simpler to reliably protect a single short seed than an arbitrary and variable number of keys. Depending on the model chosen, a single seed for all asset types may be chosen, or one per blockchain, or other granularity levels.

Regardless of the custody mechanism type—hot, warm, or cold—seeds or private keys may be stored in the secure memory of a tamper resistant system, in order to prevent their extraction, even from approved groups of signers. Indeed, a custody solution may use a hardware-based secure environment to issue signatures without exposing the key to untrusted systems (servers, workstations, and so on). In particular, hardware security modules (HSM) include defenses against invasive physical attacks, where for example the secure memory will erase all the secrets would it detect suspicious activity.

Leverage reliable security technologies: HSMs and MPC

Taurus' premier custody solution, Taurus-PROTECT, leverages HSMs for most of its deployments. These HSMs come with a FIPS 140-2 Level 3 certification, ensuring any attempts at data extraction are detected and subsequently lead to the erasure of the stored secrets. Taurus goes a step further in securing the HSM by supplementing it with a proprietary and auditable firmware extension—also known as a functional module in HSM parlance—which adds extra security hardening while facilitating the execution of business-level controls within the trusted environment of the HSM.

An alternate method of safeguarding the confidentiality of the seed involves its distribution across numerous components—ranging from systems, technologies, and locations, to companies, teams, and beyond. By fragmenting a private key into what's referred to as shards (or shares) via cryptographic techniques, it's possible to issue a signature through a process where parties exchange messages and perform calculations, ensuring that no single party has access to the complete private key. This protocol is known as threshold signing, a subfield of the broader domain of multi-party computation (MPC). Taurus has been actively exploring and investing in MPC since its establishment, resulting in several research papers and one of the industry-leading open-source software libraries, which can be found at <https://github.com/taurusgroup/multi-party-sig>.

As we'll discuss further in the rest of this article, HSM and threshold signing are not mutually exclusive technologies, and serve different purposes and different use cases. For example, if state-of-the-art HSM or secure hardware can't be used, MPC may be one's best bet to reduce the risk down to an acceptable level.

Prevent unauthorized access to signing capabilities

Even if the secret keys are not directly exposed to any party, even the solution's user, an attacker could steal funds by gaining access to the signing module if they can get it to sign arbitrary transactions. A custody solution must therefore enforce an approval mechanism, typically on a quorum basis,⁴ in such a way that the approval rules cannot be circumvented. This can for example be achieved in HSM's or secure enclave technologies. Blockchain-specific multi-signature systems may be suitable for selected use cases, but generally blockchain-agnostic solutions prove more reliable and easier to integrate and scale.

⁴ The more flexible, the better, especially for large institutions with global operations

MPC-based technologies address the approval problem by cryptographically preventing access to the key for a single party, and requiring multiple systems' interaction. One would thus have to compromise multiple computers or individuals in order to circumvent signature rules—which must be defined and reliably implemented in the first place. However, a downside of MPC is that an authorized quorum of parties can directly sign any transaction and recover the key, bypassing potential security controls regarding transaction content and type—unless a trusted execution environment is used atop the MPC layer.

Prevent unauthorized transactions

Despite limiting access to signing capabilities to authorized parties following a four-eyes principle, there remains a risk that these individuals might inadvertently or intentionally request transactions that don't comply with the business rules. To counter this risk, business processes and rules must be clearly established and securely enforced for the transactions requested. For instance, a secure environment like that of a HSM can impose security controls related to the content of transactions and the rights of the approvers. These rules may include enforcing whitelisted addresses, setting limits on transferred amounts, or defining the types of permissible smart contract operations.

Generate keys securely

Key generation is much more than picking a safe pseudorandom generator—which is actually the easiest part. Generating keys, or more accurately the seeds that will be used to derive keys, must be done during a well documented and carefully executed key ceremony, during which back-up recovery values are also created, tested, and sealed. Furthermore, one must decide whether they'd rather have a single seed for all assets or per-asset type or per-blockchain seeds. Counter-intuitively, it is often easier to protect one secret than many. One of the reasons is that if a single seed is needed, the generation and back-up process must be done only once, and the restoration tests are simpler to carry out.

Ensure reliable back-ups

A custody solution with the best cryptography and secure hardware is pointless if you don't have back-ups, or if unauthorized parties have access to back-ups of the keys, or if the back-ups will not work when needed—for example, if they're not tested. Indeed back-ups should 1) fall under shared control, for example via threshold secret-sharing mechanisms; 2) undergo rigorous testing at creation and at regular intervals—preferably at least annually; 3) be housed in tamper-evident containers and frequently inspected for any signs of tampering; and 4) be included in disaster recovery plans and procedures, as well as corresponding contingency activities.

The creation of back-ups should occur in a controlled, secure environment with multiple layers of access control to prevent unauthorized access. Importantly, the backup process should be verifiable, allowing for the periodic verification of the integrity of the backups. Notably, any staff involved in the handling of key generation and backups should undergo thorough background checks and receive training to ensure they understand and follow the security protocols. Together, these measures ensure a robust defense against both internal and external threats to keys' confidentiality and integrity.

Ensure logs and databases security

Like any contemporary computerized service, a custody solution produces vast logs and carries out various read and write operations in a database. When storing sensitive data such as personally identifiable information (PII), it's crucial to encrypt the database content. Additionally, measures to protect the integrity of this content must be robustly established. Likewise, maintaining the integrity of logs is vital to ensure any unauthorized operation can't be erased from the historical records. It goes without saying that redundant systems must be established to assure the availability of logs and databases, potentially using a multi-site distributed setup, along with failover procedures and tests for comprehensive reliability.

Ensure solution's auditability

To guarantee high security assurance, a custody solution should not operate as an entirely closed-off system, or black-box. Rather, it must offer a degree of transparency concerning its internal workings—for instance, by providing its source code to its users—and its activities, made apparent through logs generated by its various components. The ability to control and audit the solution is critical in relation to compliance audits, security audits, change management, and incident response processes. The more the provider controls the technology stack, the less opaque the solution becomes. Audit reports from credible third parties should be made available to the solution's users. As a testament to Taurus' dedication to auditability and transparency, we share the source code of our HSM firmware extension with our clients and provide our MPC library as open-source software.

Ensure supply chain and build integrity

The provider of a custody solution must ensure that the software running within the solution, whether on-premise or via a service provider, aligns with the components provided for auditing and remains unaltered during operation. These assurances necessitate a blend of technology—such as continuous integration and authentication tools—and procedures related to change management and role segregation. For instance, an organization can bolster its supply-chain security assurance by:

- 1) maintaining an auditable Continuous Integration (CI) and delivery pipeline;
- 2) facilitating audited and/or reproducible builds of critical components;
- 3) systematically scanning software dependencies and generating its software bills of materials (SBOM) in a standard format.

Ensure segregation of duties

Segregation of duties must be enforced at various levels. Firstly, between development and production. Secondly, when role-based access systems are in place, the roles must be assigned in a way that does not conflict with parties' responsibilities or information access level, yet in such a way that each role can be fulfilled by different parties (in case of absence or unavailability). Internal role change and "permission creep" must be addressed as well. To address these challenges, we found that the following controls are complementary: periodic access reviews, multi-party approval for role changes, third-party audits, and business continuity tests (such as loss of staff tests).

Key takeaway

When assessing custody technology providers, ask them which components of the value chain they control, as opposed to outsourced or subcontracted ones. The highest premium and value shall be given to those who master the full technology stack including the development and management of critical components (such as cryptographic and embedded software), which represent, in our view, the heart of the "nuclear plant". This provides the highest assurance against technology obsolescence—we have seen several providers that assemble this module not being able to cope with technology progress and their clients decide to switch. In other words, identify the builders from the assemblers who outsource the critical components. At Taurus, we control the whole stack, thus minimizing the counterparty risk, vendor lock-in risk, and need for third-party risk assessment.

III. HSM and MPC: different beasts, different roles

The previous section briefly introduced hardware security modules (HSMs) and multi-party computation (MPC), and specifically threshold signing protocols, which allow multiple computers to collectively issue a signature without exposing the full private key on any of the computers. This section will elaborate on the relative roles and merits of these two approaches.

We are sometimes asked about the merits of multi-party computation (MPC) in the context of transaction signature in custody solutions, as compared to HSMs. It is indeed tempting to compare MPC to HSM-based solutions, as if the two approaches were mutually exclusive and if one of the two was inherently superior to the other. We believe that this view is an oversimplification, as the MPC vs. HSM debate only concerns the transaction-signature layer, which is an important layer but just one among others described previously.

As we will discuss, HSM and MPC achieve different goals, serve different use cases, and may work together. One should distinguish products and services that happen to be MPC-based from MPC as a technology, and likewise for HSM.

The role of an HSM

A hardware security module (HSM) is an approach to create a **trusted execution environment (TEE)**, which in the context of a custody solution aims to:

1. Securely **store cryptographic values** (such as blockchain account seeds, keys, but also other values such as authentication tokens and certificates);
2. Ensure that the logic executed in the HSM is **computed as prescribed**, and that it does not reveal sensitive information. For example, when applying security controls such as those of the risk management layer, and when creating and signing transactions).

A state-of-the-art HSM notably relies on tamper detection systems in order to reset itself when a threat is detected. It also includes code signing mechanisms to only run authorized code. More generally, the use of an HSM facilitates the risk analysis by providing a clearly identifiable trusted computing boundary (TCB). HSMs also provide clear security assurance thanks to the applicable certification frameworks, such as FIPS 140-3 or Common Criteria. HSMs have been in production for decades, and we believe they are here to stay. For example, AWS and Google Cloud Platform provide "cloud HSM" services, complementarily to their key management services (KMS).

The role of MPC

MPC is a recent development in custody solutions and has a different purpose than HSMs: it is a class of cryptographic techniques that allows a set of participants to collectively issue a signature by running a protocol that does not expose the private key. In particular, threshold signature schemes (TSS) allow **t-of-n quorums**. MPC therefore focuses on the signature part of the transaction layer. As of today, multiple TSS protocols exist, which differ in terms of adversarial model, security assurance, features (presigning, reshare, abort), protocol rounds (for setup, signing, and other stages).

MPC is a tool of choice to mitigate the risk when only software components are used. For example, when a mobile phone application and a server application **shared control** of a key. MPC can thus address selected use cases that purely HSM-based custody may not address, because dedicated hardware cannot be used.

In principle, the shared control functionality that MPC offers can be achieved with a trusted execution environment, with the additional benefit that security controls can be enforced in a secure environment. But MPC often proves more flexible, especially with retail clientele.

Among current limitations of MPC-based technologies, note that most TSS protocols usually cannot directly support **"hardened" key derivation**, as defined in BIP32 or SLIP10 hierarchical key derivation schemes. Furthermore, back-ups as well as a key ceremony remain necessary. MPC and TSS can be nonetheless relevant tools that could even be combined with HSMs to achieve different types of deployment trade-offs.

⁵ Note that the concepts of TEE and TCB were rigorously defined in the 1985 "Orange Book"
<https://csrc.nist.gov/csrc/media/publications/conference-paper/1998/10/08/proceedings-of-the-21st-nissc-1998/documents/early-cs-papers/dod85.pdf>

MPC and security

MPC-based solutions come with unique risks and challenges, and inherit the need for a number of security controls required for any digital asset custody system. Among the critical aspects to consider when evaluating or using MPC-based solutions, one must consider the following:

- **Segregation of systems and parties**

No single party (system, person, team, provider) should have access to all the shares, as it otherwise defeats the purpose of distributing trust. For example, different nodes, running on different environments, or different data-centers, must be managed by different teams, such that no single administrator or access control solution can control multiple nodes at the same time (see Figure 3).

- **Protocol choice**

A number of protocols exist, relying on various cryptographic hardness assumptions, under various attack models (honest majority, static vs. dynamic corruptions, etc.), each with a number of internal building blocks not always fully defined in the research paper — which often are not comprehensive specifications. As the field is relatively new, a number of provably-secure protocols have been shown to have weaknesses, and some techniques are not fully understood, which call for prudence.

- **Protocol implementation**

Even if a reliable protocol is chosen, many pitfalls exist regarding its code and implementation, from software bugs to incorrect implementations and side-channel attacks. The source code should be fully auditable, and subject to security assessment by third-party cryptography experts on a regular basis. In addition, it should be continually assessed against emerging threats against protocols of the same class.

- **Key management and back-ups**

MPC does not eliminate the key management concerns, instead it tends to amplify them. In particular, processes such as key ceremonies must be in place to ensure that keys are generated in a secure environment, in an unpredictable way, with no possible leak to unauthorized parties. The software and hardware components as well as the participants must be clearly identified. In particular, there should be no ambiguity on the choice of the parameters t and n , and guarantee that no additional shares are created or copied. Also, the use of distributed key generation (DKG) and key refresh must not jeopardize the security of the system. Some implementations provide clients with a black-box key ceremony and back-ups. This is to be avoided as clients fully delegate the responsibility to the provider without being able to perform bare minimum verification. Instead, we recommend the clients to have full control on the key generation process. This might take more time but will prove valuable in case of disaster.

- **SaaS vs. on-premise**

In case of as-a-service MPC deployments, especially when the provider has access to shares of the keys (for some clients of Taurus, this set-up is unacceptable), the client must have assurance that the provider level of access is strictly limited to the required operations and access level. For example, the provider must have limited capability to monitor the financial activity of the users, and the provider must not have capabilities to tamper with business-level controls or rules. Furthermore, disaster recovery processes must be in place and tested to minimize the risk of denial-of-service or vendor lock-in.

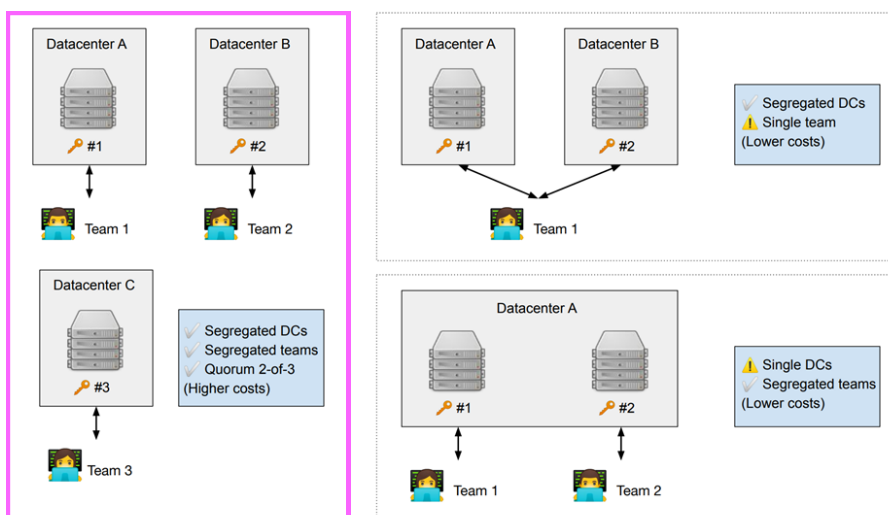


Figure 3:
IT components technical and operational segregation models: the most secure and reliable model is the 3-dataserver model (left-hand), which we recommend.

Taurus and MPC

At Taurus, we have implemented HSM-based solutions that we strengthened with our own firmware extension—now in production with the full spectrum of financial institutions,⁶ large enterprises and global brands. They work and scale well. We have also invested R&D in MPC since 2019, and developed our own MPC-based custody solution.

We have closely followed the evolution of MPC and TSS technologies, assessing the maturity and relevance of known protocols and implementations. In this context, we have notably published several research works, such as the article *Attacking Threshold Wallet*, and published the world's first open-source implementation of the MPC-CMP algorithm, which has become a standard in the industry (see <https://blog.taurushq.com/first-open-source-implementation-of-mpc-cmp/>).⁸

Based on dozens of implementations, we observe that most banks prefer HSM-based custody because they are already familiar with HSMs, and because of the simpler key management and operating processes. Banks that leverage MPC typically want full access to the code, have internal cryptography experts that are able to understand the algorithms and take responsibility of production deployment, and last but not least, have control over all the MPC shards.

That said, one of our conclusions is that a hardware root of trust (such as an HSM) is mandatory for high-assurance digital asset custody, with or without MPC.

⁶ Systemic banks, investment banks, private banks, retail banks, crypto-banks and financial market infrastructure providers.

⁷ See <https://eprint.iacr.org/2020/1052>, joint work with Omer Shlomovits, then from ZenGo.

⁸ <https://github.com/taurusgroup/multi-party-sig>

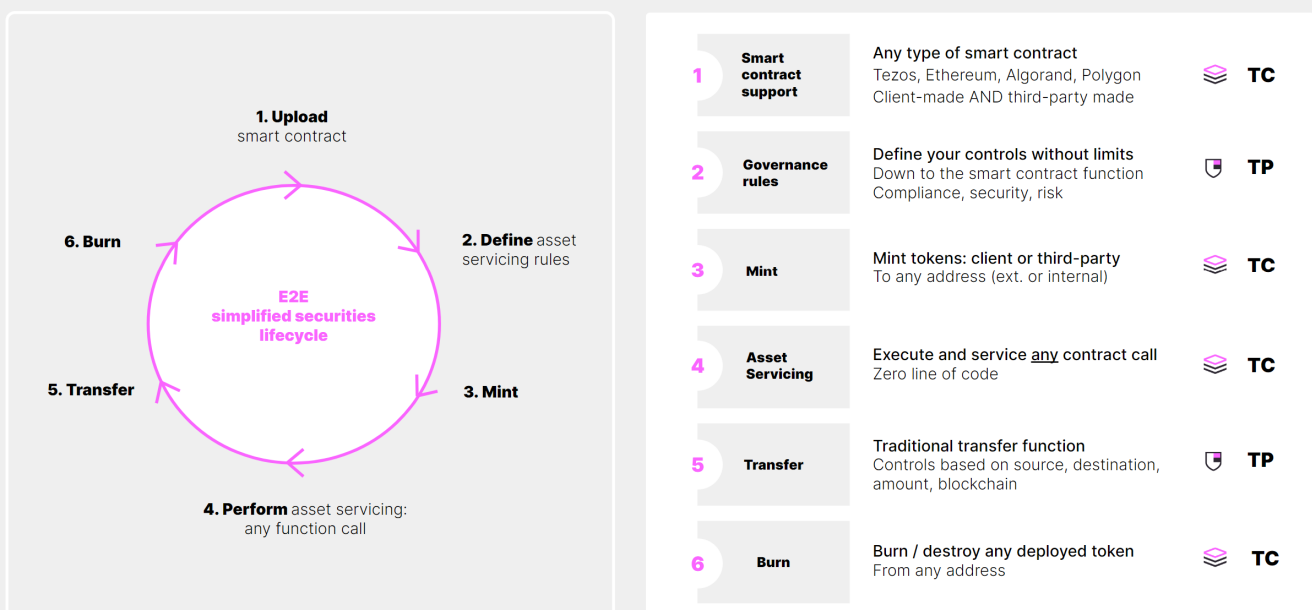
IV. Custody and servicing of securities

In the realm of financial markets, asset servicing refers to the capacity to manage assets deposited with a custodian. This encompasses essential functions such as handling corporate actions like dividend payments, coupon payments, stock splits, among others.

A digital asset custody solution must extend beyond merely safeguarding private keys and guaranteeing basic token transfers or hardcoded "mint" or "burn" functions. We contend that future-ready custody solutions should be devised in a manner that is indifferent to the specific blockchain and smart-contract technology utilized. This implies that they should be capable of providing the ability to:

- **Issue and manage tokenized assets** throughout their full lifecycle from security issuance, to corporate actions management, to security redemption ("asset lifecycle management" or ALM).
- Provide **asset lifecycle management (ALM) controls** regardless of whether:
 - The asset is fungible or not.
 - The asset is a security (equity, debt, fund, convert, structured product) or not.
 - The asset is based on a (i) standard smart contract (ii) client-custom smart contract (iii) non-smart contract blockchain feature, or (iv) third-party developed contracts.
- Provide **ALM on a cross-border basis**, taking into account the various regulatory obligations as they are. This is particularly important for corporations that have a global footprint and that need to comply with different regulations.
- Implement **banking-grade controls** and validation at the "transfer", "mint", "burn" levels but also on any other function, with zero line of code, fully integrated into the product. Associated controls such as whitelisting and blacklisting must also be supported.

At Taurus, we are proud to have developed such a custody platform.



Further reading

Below we share some resources of interest that proved valuable in our security architecture and modeling work.

References related security, reliability, hardening, and related certification frameworks:

- CMTA — Digital Asset Custody Standard, version 2.0
<https://cmta.ch/standards/digital-assets-custody-standard>
- Heather Adkins, Betsy Beyer, Paul Blankinship, Ana Oprea, Piotr Lewandowski, Adam Stubblefield — Building Secure and Reliable Systems
<https://sre.google/books/building-secure-reliable-systems/>
- NSA — Kubernetes Hardening Guide
https://media.defense.gov/2022/Aug/29/2003066362/-1/-1/0/CTR_KUBERNETES_HARDENING_GUIDANCE_1.2_20220829.PDF
- NIST Cryptographic Module Validation Program
<https://csrc.nist.gov/projects/cryptographic-module-validation-program>
- NIST SP 800-57: Recommendation for Key Management
<https://csrc.nist.gov/publications/detail/sp/800-57-part-1/rev-5/final>

Historical references on the foundations of security architecture and trusted computing:

- US National Security Agency — History of Computer Security
<https://cryptome.org/2020/10/nsa-history-computer-security-1998.pdf>
- US Department of Defense — Trusted Computer System Evaluation Criteria (“Orange Book”)
<https://csrc.nist.gov/csrc/media/publications/conference-paper/1998/10/08/proceedings-of-the-21st-nissc-1998/documents/early-cs-papers/dod85.pdf>
- Ken Thompson — Reflections on Trusting Trust
https://www.cs.cmu.edu/~rdriley/487/papers/Thompson_1984_ReflectionsonTrustingTrust.pdf

General references about cryptography:

- Jean-Philippe Aumasson — Serious Cryptography
<https://nostarch.com/seriouscrypto>
- Mike Rosulek — The Joy of Cryptography
<https://joyofcryptography.com/>
- David Wong — Real-World Cryptography
<https://www.manning.com/books/real-world-cryptography>

Example of state-of-the-art MPC protocol:

- Ran Canetti, Rosario Gennaro, Steven Goldfeder, Nikolaos Makriyannis, Udi Peled — UC Non-Interactive, Proactive, Threshold ECDSA with Identifiable Aborts
<https://eprint.iacr.org/2021/060>
- Deirdre Connely, Chelsea Komlo, Ian Goldberg, Christopher A. Wood — Two-Round Threshold Schnorr Signatures with FROST
<https://datatracker.ietf.org/doc/draft-irtf-cfrg-frost/>
- Jack Doerner, Yashvanth Kondi, Eysa Lee, abhi shelat — Threshold ECDSA in Three Rounds
<https://eprint.iacr.org/2023/765>
- Rosario Gennaro, Steven Goldfeder — One Round Threshold ECDSA with Identifiable Abort
<https://eprint.iacr.org/2020/540>

CONTACT

contact@taurusgroup.ch



<https://www.taurushq.com>



<https://www.t-dx.com>

IMPORTANT DISCLOSURE ABOUT THIS DOCUMENT

The information and opinions in this article were prepared by Taurus SA ("Taurus"). Taurus or the writer of this article may have significant financial interest in one or several digital assets. Taurus does not provide individually tailored investment advice. This article has been prepared without regard to the circumstances and objectives of those who receive it. Taurus recommends that investors independently evaluate particular investments and strategies, and encourages investors to seek the advice of a financial adviser. The appropriateness of an investment or strategy will depend on an investor's circumstances and objectives. The securities, financial instruments, or strategies discussed in this article may not be suitable for all investors, and certain investors may not be eligible to purchase or participate in some or all of them. This paper is not an offer to buy or sell or the solicitation of an offer to buy or sell any digital assets or to participate in any particular trading strategy. The value of digital assets may vary a lot because of changes in interest rates, foreign exchange rates, default rates, prepayment rates, securities/instruments prices, market indexes, operational or financial conditions of companies or other factors. Past performance is not necessarily a guide to future performance. Estimates of future performance are based on assumptions that may not be realized. This article is based on public information. Taurus makes every effort to use reliable, comprehensive information, but we make no representation that it is accurate or complete. We have no obligation to tell you when opinions or information in our research change apart from when we intend to discontinue equity research coverage of a subject company. Taurus may make investment decisions that are inconsistent with the recommendations or views in this report. All copyrights are the property of Taurus. It is strictly forbidden to copy this research in full or in part without the explicit authorization of Taurus.